

Présenté par : **Serigne Sam MBAYE**
L3 SRT A

Atelier 3 : Scanner avec nmap

Pour cet atelier, nous allons scanner la VM Metasploitable2 en utilisant **nmap**.

Partie 1 - Configuration

Lancez à la fois Kali Linux et la VM Metasploitable2 et assurez-vous qu'elles sont sur le même réseau isolé.

Vérifiez la version de **nmap** que vous avez installée. Les commandes **nmap** ont légèrement évolué au fil du temps. Il est important de s'assurer que vous suivez la documentation de la version du programme que vous utilisez.

```
$ nmap --version
```

```
(root@Sam)-[/home/sam]
# nmap --version
Nmap version 7.95 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.7 openssl-3.5.4 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.5 nmap-libdnet-1.12 ipv6
Compiled without:
Available nsock engines: epoll poll select

(root@Sam)-[/home/sam]
#
```

Livrables :

- Quelle est l'adresse IP de votre VM Kali Linux ? : 10.0.2.3

```
(root@Sam)-[/home/sam]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.3 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fef2:3aaf prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:f2:3a:af txqueuelen 1000 (Ethernet)
    RX packets 6 bytes 2480 (2.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 32 bytes 5098 (4.9 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Boucle locale)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(root@Sam)-[/home/sam]
#
```

- Quelle est l'adresse IP de votre VM Metasploitable2 ? ; 10.0.2.4

```
root@metasploitable:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:c5:3f:c6
          inet addr:10.0.2.4  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fec5:3fc6/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:31 errors:0 dropped:0 overruns:0 frame:0
          TX packets:99 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6022 (5.8 KB)  TX bytes:13230 (12.9 KB)
          Base address:0xd240 Memory:f0820000-f0840000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:170 errors:0 dropped:0 overruns:0 frame:0
          TX packets:170 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:56737 (55.4 KB)  TX bytes:56737 (55.4 KB)

root@metasploitable:~# _
```

- Quelle version de nmap avez-vous installée dans Kali (réponse sous la forme : x.xx) ?

➤ C'est la version Nmap version 7.95

Attention : si les deux systèmes ont la même adresse IP et que vous utilisez VirtualBox, il est probable que vous n'avez pas complété la partie « Configuration de la mise en réseau » du TP « configuration de la machine virtuelle ».

Partie 2 - Découverte des hôtes

Effectuez un scan de découverte d'hôtes avec `nmap` sans scan de port. Normalement, ceci devrait être utilisé pour scanner un **sous-réseau entier (ou plus grand)**, mais pour ce TP, nous allons cibler des IP spécifiques.

Tout d'abord, ciblez uniquement la VM Metasploitable2 à travers son adresse IP.

```
$ sudo nmap -sn 10.0.2.4
```

```
-d[level]: Set or increase debugging level (Up to 9 is meaningful)
--open: Only show open (or possibly open) ports
--packet-trace: Show all packets sent and received
--iflist: Print host interfaces and routes (for debugging)
--log-errors: Log errors/warnings to the normal-format output file
--append-output: Append to rather than clobber specified output files
--resume <filename>: Resume an aborted scan
--stylesheet <path/URL>: XSL stylesheet to transform XML output to HTML
--webxml: Reference stylesheet from Insecure.Org for more portable XML
--no-stylesheet: Prevent associating of XSL stylesheet w/XML output
MISC:
-6: Enable IPv6 scanning
-A: Enables OS detection and Version detection, Script scanning and Traceroute
--datadir <dirname>: Specify custom Nmap data file location
--send-eth/--send-ip: Send using raw ethernet frames or IP packets
--privileged: Assume that the user is fully privileged
--unprivileged: Assume the user lacks raw socket privileges
-U: Print version number
-h: Print this help summary page.
EXAMPLES:
nmap -v -A scanme.nmap.org
nmap -v -sP 192.168.0.0/16 10.0.0.0/8
nmap -v -iR 10000 -PN -p 80
SEE THE MAN PAGE FOR MANY MORE OPTIONS, DESCRIPTIONS, AND EXAMPLES
root@metasploitable:~# _
```

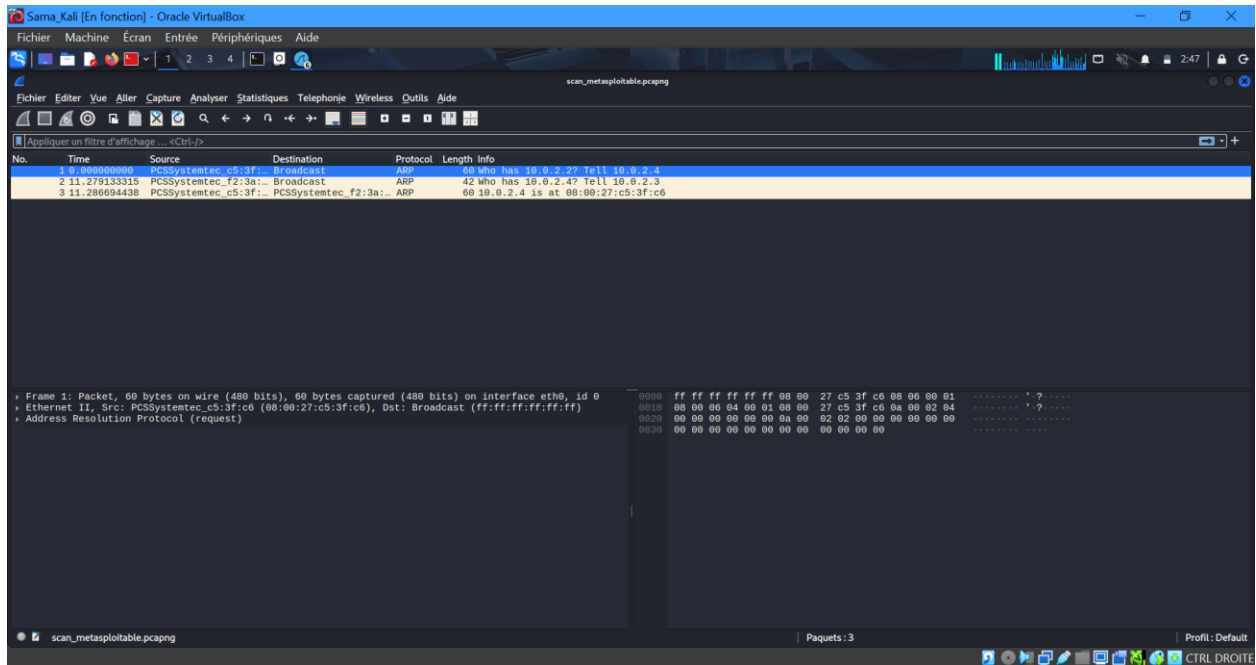
Remarque : utiliser sudo pour que **nmap** puisse générer des paquets réseau arbitraires pour ce scan.

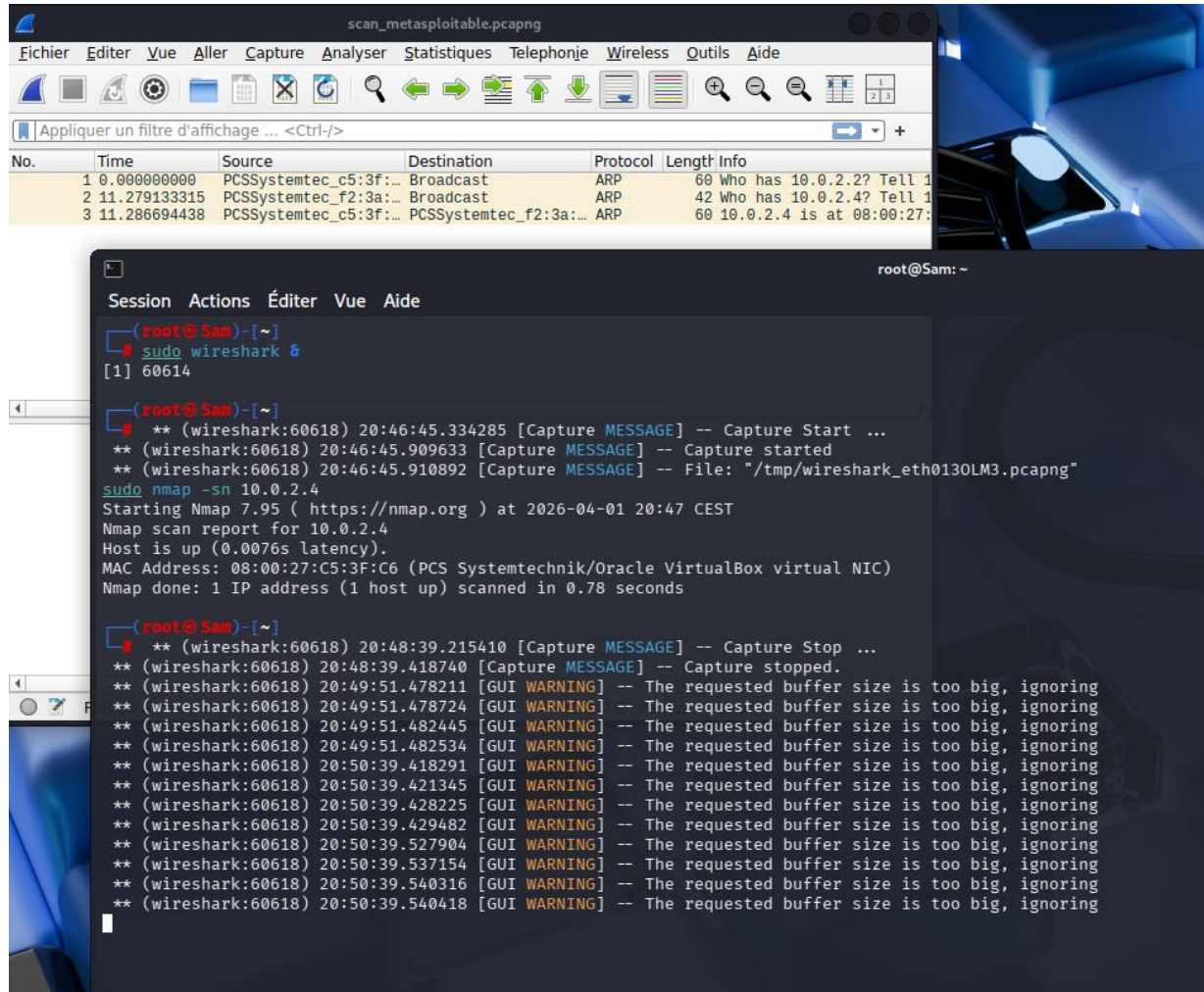
Selon la documentation de **nmap** : la découverte de l'hôte par défaut effectuée avec **-sn** consiste en une requête ICMP echo, TCP SYN vers le port 443, TCP ACK vers le port 80, et une requête ICMP timestamp par défaut. Lorsqu'elle est exécutée par un utilisateur non privilégié, seuls les paquets SYN sont envoyés (à l'aide d'un appel de connexion) aux ports 80 et 443 sur la cible. Lorsqu'un utilisateur privilégié tente d'analyser des cibles sur un réseau ethernet local, des requêtes ARP sont utilisées, sauf si **--send-ip** a été spécifié. – <https://nmap.org/book/man-host-discovery.html>

Livrables :

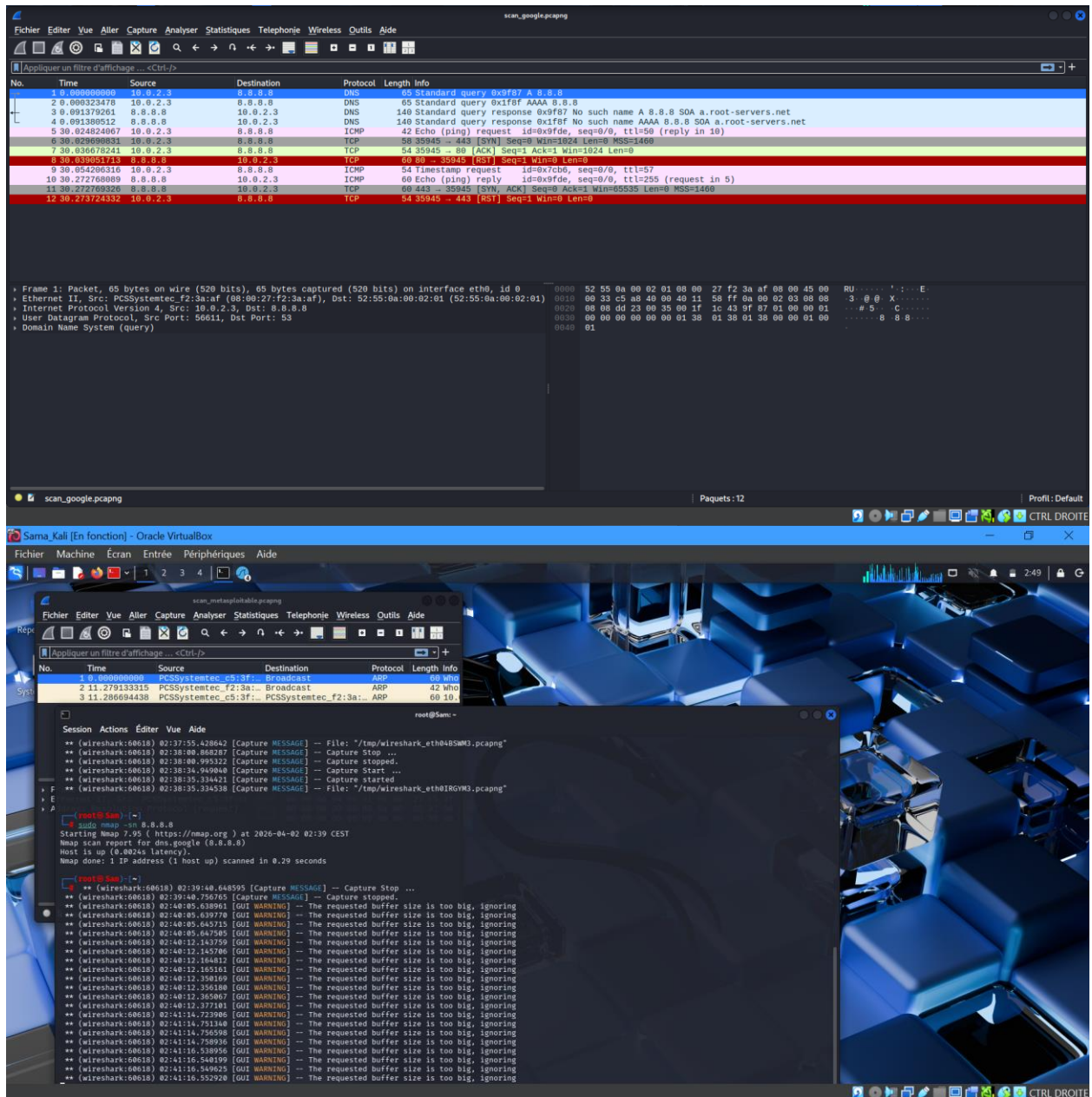
- Quelles sont les méthodes utilisées par nmap pour effectuer la découverte des hôtes lorsqu'il est exécuté en tant qu'utilisateur root (c'est-à-dire via sudo) ?
 - Lorsque nmap est exécuté en tant que **root sur un réseau local Ethernet**, il utilise des **requêtes ARP** pour découvrir les hôtes. nmap a envoyé un **ARP Request** ("Who has 10.0.2.4? Tell 10.0.2.3"), et quelques millisecondes plus tard, la VM Metasploitable2 a répondu avec un **ARP Reply** ("10.0.2.4 is at 08:00:27:C5:3F:C6"), confirmant qu'elle est active.
- Pour documenter votre réponse, exécutez Wireshark en arrière-plan et capturez uniquement le scan réseau de nmap avec l'option **-sn**, sans trafic

réseau supplémentaire (ou avec un minimum). Enregistrez et téléchargez le fichier .pcapng résultant.





Ensuite, ciblez l'adresse IP **8.8.8.8**, qui correspond au serveur DNS public de Google (une fonction connue sous le nom de « IP Anycast »). Comme précédemment, faites simplement un scan de découverte d'hôte avec nmap sans scan de port.



Livrables :

- Quelle commande avez-vous saisie pour exécuter le scan en tant qu'utilisateur root ?
 - `sudo nmap -sn 8.8.8.8`
- Quelles méthodes `nmap` utilise-t-il pour effectuer la découverte des hôtes lorsqu'il est exécuté en tant qu'utilisateur root ?

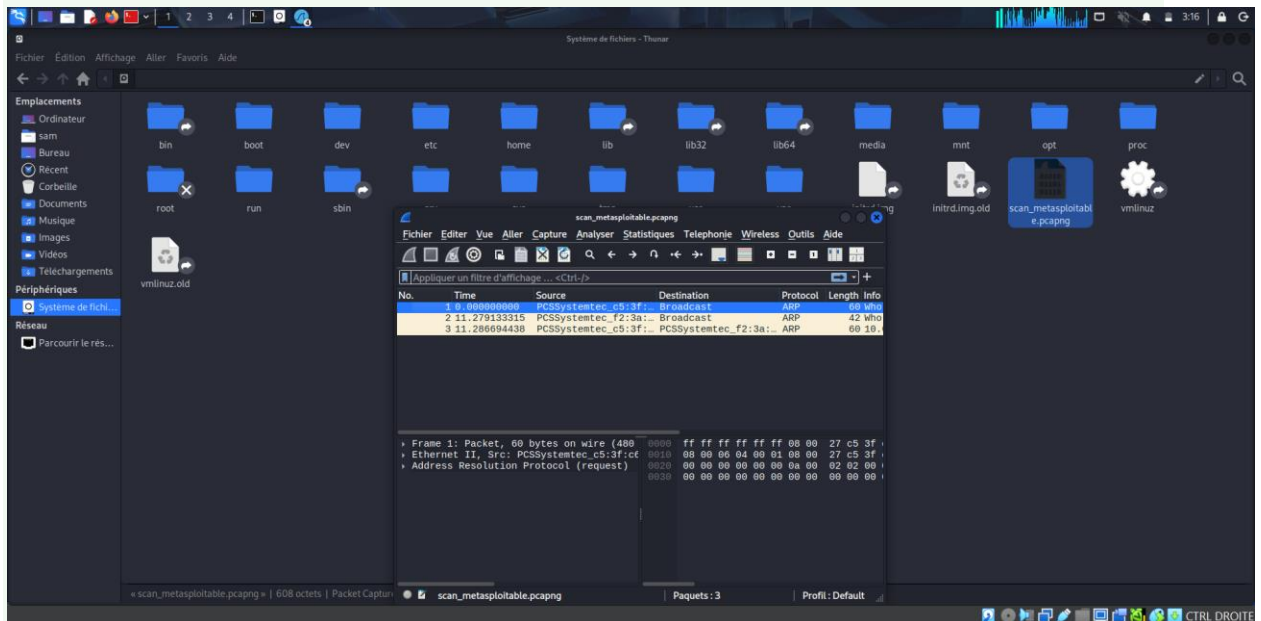
- Puisque 8.8.8.8 est une adresse **distante (hors réseau local)**, nmap ne peut pas utiliser ARP. Les méthodes observées dans la capture Wireshark sont :

ICMP Echo Request (ping)

TCP SYN vers le port 443

DNS PTR Request (résolution inverse de 8.8.8.8.in-addr.arpa)

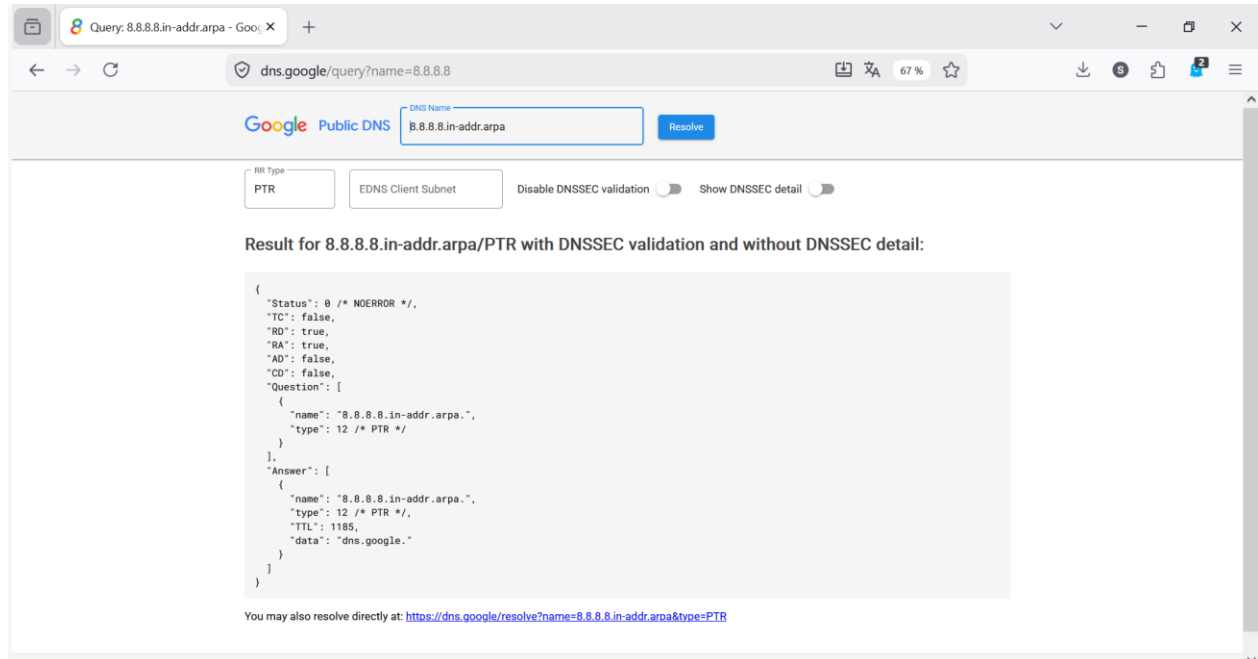
Pour documenter votre réponse, exécutez Wireshark en arrière-plan et capturez uniquement le scan réseau de nmap avec l'option -sn, sans trafic réseau supplémentaire (ou avec un minimum). Enregistrez et téléchargez le fichier .pcapng obtenu.



- Quel est le nom de l'hôte qui répond à la requête DNS inverse envoyée par nmap pour 8.8.8.8.in-addr.arpa ? Vous pouvez obtenir cette information à partir de la trace Wireshark que vous venez d'obtenir.

- dns.google

(Astuce : vous pouvez taper ce nom d'hôte dans votre navigateur web et voir une page web qui devrait immédiatement confirmer l'exactitude de votre réponse).



- Dans un court paragraphe, expliquez quelles réponses sont reçues suite à la découverte de l'hôte par nmap. Formulez votre réponse dans le format suivant : nmap a envoyé <message de demande>, et quelques paquets plus tard, l'hôte cible a envoyé <message de réponse>.
- nmap a envoyé une **requête ICMP Echo Request (ping)** ainsi qu'une **requête DNS PTR pour 8.8.8.8.in-addr.arpa** et des **sondes TCP SYN vers le port 443**, et quelques paquets plus tard, l'hôte cible (8.8.8.8) a envoyé un **ICMP Echo Reply** confirmant qu'il est actif, ainsi qu'une **réponse DNS PTR** indiquant le nom d'hôte dns.google.

Partie 3 – Scan des ports TCP

Effectuez un scan des ports TCP avec nmap sur la VM Metasploitable2 pour détecter les services actifs. Un scan de connexion (**-sT**) ou un scan SYN (**-sS**) est suffisant.

```
$ sudo nmap -sT 10.0.2.4
```



```
(root@Sam)-[~]
# sudo nmap -sT 10.0.2.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:40 CEST
Nmap scan report for 10.0.2.4
Host is up (0.021s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:C5:3F:C6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 12.09 seconds

(root@Sam)-[~]
#
```

\$ sudo nmap -sS 10.0.2.4

```
(root@Sam)-[~]
# sudo nmap -sS 10.0.2.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 03:27 CEST
Nmap scan report for 10.0.2.4
Host is up (0.0059s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:C5:3F:C6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.45 seconds

(root@Sam)-[~]
#
```

Remarque : utiliser sudo pour que nmap puisse générer des paquets réseau arbitraires pour ce scan.

Livrables :

- Quels sont les ports et services spécifiques que nmap trouve ouverts ? Copiez et collez le tableau **PORT | STATE | SERVICE** dans son intégralité.

PORT	STATE	SERVICE
21/tcp	open	ftp
22/tcp	open	ssh
23/tcp	open	telnet
25/tcp	open	smtp
53/tcp	open	domain
80/tcp	open	http

```
111/tcp open  rpcbind
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
512/tcp open  exec
513/tcp open  login
514/tcp open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
```

- Combien de ports sont ouverts selon nmap ?
 - 23 ports ouverts
- Combien de ports sont fermés selon nmap ?
 - 977 ports fermés

Partie 4 – Scan des ports UDP

Effectuer un scan des ports UDP avec nmap sur la VM Metasploitable2 pour détecter les services actifs.

```
$ sudo nmap -sU CIBLE
```

Remarque : utiliser sudo pour que nmap puisse générer des paquets réseau arbitraires pour ce scan.

Conseil 1 : contrairement à TCP, il n'y a pas de moyen générique de voir si un port UDP est ouvert ou non, puisque UDP est sans connexion. Ainsi, vous obtiendrez des résultats beaucoup plus précis (et serez en mesure de répondre à la question du TP) si vous activez également le scan de service et de version avec votre scan UDP.

Conseil 2 : si vous acceptez les options par défaut, ce scan prendra beaucoup de temps. Cependant, vous pouvez faire en sorte que nmap aille plus vite en spécifiant un [modèle de temporisation](#) autre que celui par défaut. Étant donné que la cible est une VM sur le même ordinateur (encore mieux que sur le même réseau local !), des délais plus courts devraient être parfaitement sûrs.

Conseil 3 : si vous ne vous intéressez qu'aux services les plus populaires (ce qui est suffisant pour ce TP), vous pouvez utiliser l'argument `--top-ports=N` pour ne scanner que les **N** ports de service les plus populaires.

Livrables :

- Quelle commande avez-vous entrée pour faire un scan plus rapide des ports UDP et pour activer également le scan des services et des versions ?
- Quels sont les 4 ports UDP que nmap a trouvé comme étant ouverts (pas ouverts|filtrés, juste ouverts) et quels sont les services qui fonctionnent sur ces ports ? Donnez votre réponse dans l'ordre numérique croissant.

Partie 5 – Détection du système d'exploitation (OS)

Effectuez un scan de détection d'OS avec `nmap` sur la VM de Metasploitable2. Notez que la détection d'OS implique implicitement la découverte des ports.

```
$ sudo nmap -O CIBLE
```

Remarque : utiliser sudo pour que nmap puisse générer des paquets réseau arbitraires pour ce scan.

Livrables :

- Quel est le type de périphérique de la VM Metasploitable2 selon nmap ?
- Quelle est la chaîne CPE (Common Platform Enumeration) de la VM Metasploitable2 ?
- Quelle est la chaîne OS Details fournie par nmap pour la VM Metasploitable2, montrant la gamme de versions de noyau qu'il pense que l'hôte exécute ?
- Vérifiez la VM Metasploitable2 – Quelle version de noyau exécute-t-elle réellement ? (Fournissez votre réponse sous la forme x.x.x-x-tag)

Partie 6 – Scan des versions et des services

Effectuez un scan de version et de service de la VM Metasploitable2 :

```
$ sudo nmap -sV CIBLE
```

Remarque : utiliser sudo pour que `nmap` puisse générer des paquets réseau arbitraires pour ce scan.

Livrables :

- Quelle version d'OpenSSH est utilisée ?
- Quelle version du serveur DNS BIND est en cours d'exécution ?

Partie 7 - Analyse complète

Effectuez un scan « tout et n'importe quoi » contre la VM Metasploitable2 en utilisant l'option `-A` (pour tous). Il s'agit de l'analyse la plus longue (au moins pour TCP) et la plus verbeuse. En tant que tel, il est préférable de l'exécuter contre des hôtes très spécifiques dont (a) vous connaissez l'existence et (b) vous savez qu'ils possèdent des services spécifiques qui vous intéressent.

```
$ sudo nmap -A CIBLE
```

Remarque : utiliser sudo pour que `nmap` puisse générer des paquets réseau arbitraires pour ce scan.

Livrables :

- Quel est le groupe de travail NetBIOS du serveur Samba sur la VM de Metasploitable2 ?
- Quelle est la clé hôte RSA SSH de 2048 bits qui identifie cette cible ?

Formulaire de dépôt :

- L3SRT-A : <https://forms.gle/dgcdufp64cVVkwy79>
- L3SRT-B : <https://forms.gle/oPB4fSibhAXiDuf78>